

Ransomware Tabletop Exercise

Incident response scenario, expected decisions, and after-action improvement plan

Entity	Sample Enterprise (fictional)
Prepared By	GRC Analyst Portfolio
Exercise Type	Tabletop
Threat Theme	Ransomware
Version	1.0

Prepared by Gustavo do Carmo Lemes to practice designing and facilitating a tabletop exercise, from scenario design through after-action reporting.

1. Scenario Summary

This tabletop exercise simulates a ransomware event initiated through a successful phishing email sent to the finance function. The scenario challenges incident command, containment, communications, and business recovery decision-making.

2. Exercise Objectives

- Validate incident triage and escalation paths.
- Assess whether leadership receives timely, decision-ready information.
- Test alignment between security, IT operations, legal, and communications.
- Identify gaps in backup assumptions, endpoint containment, and third-party coordination.

3. Key Timeline

Time	Inject / Event	Expected Team Response
08:15	Finance user reports unusual file encryption and ransom note	Open severity-one incident and isolate affected endpoint
08:40	Multiple shared drives become inaccessible	Trigger broader containment and review identity compromise indicators
09:00	Customer support reports service disruption	Engage business continuity lead and executive communications
10:00	Threat actor claims exfiltration of data	Coordinate legal, privacy, and notification decision-making

4. After-Action Improvements

1. Predefine authority to isolate devices and disable accounts during high-confidence ransomware events.
2. Maintain a current executive notification matrix with legal and privacy contacts.
3. Verify recovery priorities for customer-critical applications and shared services.
4. Document decision criteria for involving cyber insurance, outside counsel, and law enforcement.